EWB Courses – AI-Powered Cybersecurity
Assessment 01: Security Foundations – Final Report
Name: Sukesh.S
Batch/Group: Ewb AI POWERED CYBERSECURITY INTERNSHIP
Date: 28.10.26

Task A | Secure a Student Account

A1 and A2 – Risks, assets, CIA impact, controls and limitations

Risk	Asset	CIA impact	Control	Limitation
Reused short password	Email and learning portal accounts	Confidentiality – if one account is guessed or leaked, both fall	Make a long unique passphrase for each account, stored in a password manager	Takes effort to change and set up; older breaches may already have the old password
Approving unexpected sign-in prompts	Learning portal account	Confidentiality – an attacker gets into the account with the user's own approval	Only approve an MFA prompt that you started yourself; deny and report all others	Under pressure, people can still tap approve by mistake, which is exactly what attackers want
Postponing device updates	Laptop and the data on it	Integrity and availability – unpatched flaws let malware in, which can corrupt or lock files	Turn on automatic updates and restart when asked	Updates need restarts and a bit of time; some fixes still leave other gaps
Only one copy of the project, on one laptop	Project work	Availability – theft, damage or ransomware means the work is simply gone	Keep two backups, one in the cloud and one external drive, updated on a fixed schedule	Backups can silently fail or sync an old version if nobody checks them

Risk	Asset	CIA impact	Control	Limitation
Friend using the laptop under Mira's signed-in account	Mira's account and her files	Integrity and confidentiality – anything the friend does appears as Mira's actions; files can be changed or seen	Lock the screen (Win+L) every time she steps away, and give the friend a separate guest account	It feels inconvenient, so people stop doing it over time

Priority order and why
First, change the passwords to long unique ones – this closes the door that is most likely already half-open, since a reused short password is the easiest thing for an attacker to use. Second, fix the MFA habit (only approve prompts you started) – even if the password leaked, this blocks an outsider from getting in. Third, set up backups for the project – updates can wait a day or two, but losing the only copy cannot be undone. The password and MFA fixes protect against an active threat; the backup protects against a single point of failure.

A3 – Authentication vs authorisation

Authentication is proving who you are. On Mira's learning portal, signing in with her username, password and the MFA code is authentication – the portal checks that she is really Mira. Authorisation is what she is allowed to do after that. Once logged in, Mira can see her own courses and submit her work, but she cannot see another student's marks or change course settings – that is authorisation deciding what her account may touch. So authentication answers 'who are you?', and authorisation answers 'what may you do?'. If either one is weak, the account is not really protected.

Task B | Analyse a Suspicious Message

B1 – Five warning signs

No.	Warning sign (phrase from the message)	Why it needs scrutiny
1	'Reply-To: help@personal-awards.example'	The reply address is a personal domain, not the college's campus.example. Genuine college mail normally stays inside the college domain.
2	'FINAL WARNING - scholarship expires in 20 minutes'	Extreme urgency with a countdown is a classic pressure trick to stop the reader from thinking or checking.
3	'enter your college password and OTP'	No legitimate scholarship desk ever needs your portal password or OTP. Those are meant for signing in only.
4	'Do not contact the college office because their system is unavailable'	Stopping you from verifying through the proper channel is a red flag; real offices tell you to verify.
5	'Reply with a photo of your identity card'	Identity documents should not be sent to unknown email addresses; this is identity-theft material.

B2 – Safe verification process

1. Do not click any link in the message and do not reply to it.
2. Open the college's official site or app by typing campus.example yourself, or use a contact number from the official website or printed student handbook.
3. Log in through that normal route and check whether any scholarship status or notice exists there.
4. If nothing appears, contact the scholarship/finance office through the official number or in person and read them the message to confirm.

HTTPS only means the connection is encrypted between you and the server – a scam site can also have a valid HTTPS certificate. A familiar display name is just free text that anyone can set. So neither one proves who actually runs the page; only an address you reached independently does.

B3 – Response plan if a password and OTP were already entered

1. Contain now: change the college portal password immediately from a clean device, and change the email password too if the same or similar password was reused.
2. Re-secure: sign out of all active sessions on the portal, and re-register or reset MFA if the portal allows it, so stolen tokens stop working.
3. Report: inform the college IT/security office through the official portal or helpline, and forward the suspicious message to them. Do not send anyone your password or OTP, and tell the student never to send those either.
4. Follow up: check recent sign-in activity and mail forwarding rules for the next few days, watch for lockout or new unknown alerts, and flag the ID document sent – ask the office what to do, and stay alert to misuse of it.

B4 – What cannot be established from this message alone

From the message alone we cannot tell who actually sent it or whether the linked verify page was set up by an attacker – sender addresses and display names can be spoofed, and we have no server logs or domain registration data to check. Evidence that would help: the full email headers (true sending server and route), and WHOIS/registration records for campus-awards.example showing who owns the domain and when it was created.

Task C | Triage a Sign-in Alert

C1 – Observed vs Interpretation

Point 1 – Observed: At 09:00–09:01, student07 signs in from 192.0.2.10 (the usual classroom egress) with password success and MFA approved. Interpretation: this looks like the student's normal morning session, consistent with the statement 'I did not sign in after 09:05'.
Point 2 – Observed: At 10:14–10:16, from a different IP 198.51.100.23, there are two password failures followed by a

password success. Interpretation: someone knew or guessed the password on the third try – possible password stuffing or guessing; the repeated attempts hint at automated guessing, but it could also be the student mistyping.
Point 3 – Observed: At 10:17 and 10:18, two MFA prompts come from the same new IP; the first is denied, the second approved. Interpretation: this fits MFA fatigue/prompt bombing – repeated pushes until the user taps approve, which the statement supports: the student says they approved the 10:18 prompt only to make the requests stop.
Point 4 – Observed: At 10:20, a session is created from 198.51.100.23. Interpretation: after the approved MFA, that new IP held an active session – so the account may have been accessed by whoever triggered the prompts.

C2 – Explanation, alternative and further checks

Likely explanation: an attacker obtained or guessed the password and used MFA fatigue – sending push after push from 198.51.100.23 until the student, tired of the alerts, approved one. The two failures at 10:14–10:15 and the approval at 10:18 fit this pattern, and the student's own statement confirms an approval they did not intend.
Alternative explanation: it could be the student (or someone using their device) signing in from a new network, say mobile data or home internet, mistyping the password twice and then approving their own legitimate prompt – which would also explain why they later approved prompts they say were annoying.
Two additional checks to distinguish them: (1) Ask the student where they physically were at 10:14–10:20 and check if 198.51.100.23 matches their known home/mobile network or a device fingerprint from their usual devices. (2) Pull any logs around those minutes – which device/browser, user agent, and whether a new session came with an unfamiliar device profile.
Note: a different source IP alone does not identify a person or prove an attacker; it is only one signal among several.

C3 – Three prioritised response actions for the IT team

1. Protect and contain first – revoke the active session from 198.51.100.23, force a password reset, and reset MFA registration. This stops further access within minutes.
2. Preserve evidence – take a copy of the full sign-in logs, session metadata and any alert records before they rotate out, so the timeline can be reviewed and audited later.
3. Investigate and monitor – check the account for what that session touched (files, settings, forwarded mail), verify with the student what they did and did not approve, and keep a temporary watch on the account for further anomalous sign-ins.

C4 – Incident summary

On 18 October 2026, student07's account shows two failed password attempts from 198.51.100.23 at 10:14-10:15, then a password success at 10:16, an MFA denial at 10:17 and an MFA approval at 10:18, creating a session at 10:20. The student states they did not sign in after 09:05 and approved the 10:18 prompt only to stop repeated requests, suggesting possible MFA fatigue by an attacker, though an unknown new device or network cannot be ruled out yet. Priority is to confirm the details with the student, contain the account and preserve logs, and next investigate what the 10:20 session accessed.

Task D | Review an AI Security Answer

D1 – Five unsafe or unsupported claims, corrected

1. 'The email is safe because it uses HTTPS' – Wrong. HTTPS only encrypts traffic to the site; scam sites can also have valid HTTPS certificates. HTTPS says nothing about who owns the page or whether it is trustworthy. The right question is whether the address was reached through an independent, official channel.

2. 'The sign-in logs prove that the person using 198.51.100.23 stole the password' – Unsupported. The logs show a different IP, but they do not show who was behind it; the IP could be a new network, mobile hotspot or shared address, and IP alone does not identify a person. The logs are a clue, not proof.
3. 'MFA prevents every account compromise' – Overstated. MFA reduces risk a lot, but this very case shows it can be bypassed by MFA fatigue (repeated prompts until the user approves one). Other bypasses exist too, like SIM-swap, stolen OTPs or compromised sessions, so it is not absolute.
4. 'Delete the suspicious logs' – Unsafe. Logs are the primary evidence of what happened; deleting them destroys the ability to investigate and may violate policy or law. They should be preserved and handed to the security team.
5. 'Send the student's password to support so they can test it' – Unsafe. Passwords must never be shared with anyone, including IT; a genuine support team never needs them, and sending them would make the compromise worse. The right action is a password reset performed by the student.

D2 – A better prompt for an AI tool

'You are a cybersecurity teaching assistant. Using only the synthetic evidence I paste below (a fictional email and a small log table, all from training data), analyse Task B and Task C of this assessment. Clearly separate observed facts from your assumptions, state your confidence level for each conclusion, and say clearly when something cannot be determined from the evidence. Do not request or suggest using any real passwords, OTPs, personal data or live websites. Give practical, prioritised next steps for a student-level response.'

D3 – My own corrected security advice

Do not treat HTTPS, a padlock icon or a familiar name in the From line as proof a message is genuine – these can all be faked or belong to a scam site. For anything urgent involving money, scholarships or passwords, always verify through a

channel you open yourself: type the official address, use the official app or call the number from the handbook. Never enter a password or OTP on a page you reached from a link in an unexpected message. MFA is a strong layer, but it can be worn down – if prompts arrive that you did not start, deny them and change your password rather than approving to make them stop. Finally, if an account may be compromised, change the password, reset MFA, report through the official channel and keep the evidence; never delete logs or share credentials with anyone. I compared this against the fictional AI output and checked my reasoning against the CISA Secure Our World guidance.

D4 – AI-use declaration and references

AI-use declaration: I used an AI assistant to help draft and organise my answers for this report. I reviewed and rewrote the content in my own words, verified the concepts against the references below, and take full responsibility for the final answers. No real passwords, OTPs, personal data or live systems were used.

Evidence/Reference notes:

1. CISA – Secure Our World (basic account and phishing guidance): https://www.cisa.gov/secure-our-world – supports the account security, phishing and MFA habits discussed in Tasks A, B and D.
2. NIST – Generative AI Profile, AI 600-1 (confabulation and verification): https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf – supports the point that AI outputs must be verified rather than trusted blindly, which is the basis of the corrections in D1.